

PayVault™ Digital Wallet Mobile Application

Meridian Pay Technologies, Inc. (fictitious)

Version 1.0 • July 2026 • Classification: Internal (Sample)

DISCLAIMER: This document is an entirely fictitious training artifact. The company, product, personnel, figures, incidents, and third parties described herein are invented for educational purposes and do not describe any real system.

Table of Contents

Table of Contents.....	2
1. Executive Summary.....	3
2. Business Context.....	3
2.1 Company Profile (Fictitious).....	3
2.2 Business Cases Driving the Product	3
2.3 Regulatory and Compliance Drivers.....	3
3. System Architecture.....	4
3.1 Architecture Overview	4
3.2 Component Inventory	4
4. Business Case for the Security Investment	5

1. Executive Summary

This case study documents a full-lifecycle application called PayVault, the flagship digital wallet mobile application of Meridian Pay Technologies, Inc., a fictitious Atlanta-based fintech serving 4.2 million monthly active users. The production architecture of the planned launch is in Q4 2026.

2. Business Context

2.1 Company Profile (Fictitious)

Meridian Pay Technologies operates PayVault, a consumer digital wallet offering peer-to-peer transfers, tokenized card payments (NFC and in-app), bill pay, and a micro-savings vault. The company is a licensed money transmitter in 47 U.S. states, partners with a sponsor bank for FDIC pass-through deposit insurance, and processes approximately \$1.8B in annualized total payment volume (TPV).

2.2 Business Cases Driving the Product

The threat model is anchored to the business capabilities the platform must protect. Each business case carries distinct assets, abuse incentives, and regulatory exposure:

Business Case	Description	Revenue Model	Annual Value (est.)	Primary Abuse Incentive
P2P Transfers	Instant transfers between wallet users; core growth engine	Free (funded by float and interchange halo)	\$0 direct; drives 61% of MAU	Money-mule networks, scams, ATO
Tokenized Card Payments	NFC and in-app payments via network tokenization	Interchange share (~0.35% of TPV)	\$4.6M	Card-testing, PAN harvesting
Bill Pay	Utility and subscription payments from wallet balance	Per-transaction fee \$0.49	\$2.1M	Payment redirection fraud
Micro-Savings Vault	Round-up savings with 3.8% APY via sponsor bank	Net interest margin share	\$1.7M	Bonus/APY abuse, synthetic IDs
Intl. Remittance (Q4 launch)	Instant cross-border transfers to 14 corridors	FX spread 1.2% + fee	\$6.0M (yr-1 projection)	Sanctions evasion, laundering

2.3 Regulatory and Compliance Drivers

- PCI DSS v4.0 - the token vault and payment authorization path form the cardholder data environment (CDE).

- BSA/AML and state money-transmitter obligations - KYC, transaction monitoring, and SAR filing for P2P and remittance flows.
- GLBA Safeguards Rule and state privacy statutes - protection of consumer financial data, including data shared with third-party SDKs.
- Sponsor-bank oversight - contractual audit rights and incident-notification requirements flow down from the partner bank.

3. System Architecture

3.1 Architecture Overview

PayVault follows a mobile-first, microservices architecture deployed in a single cloud provider across three availability zones. The mobile app communicates exclusively through a WAF-fronted API gateway enforcing OAuth 2.0 with mutual TLS for service-to-service calls. Card primary account numbers (PANs) never touch general-purpose services: they are tokenized on entry and stored only in an HSM-backed token vault inside the PCI CDE.

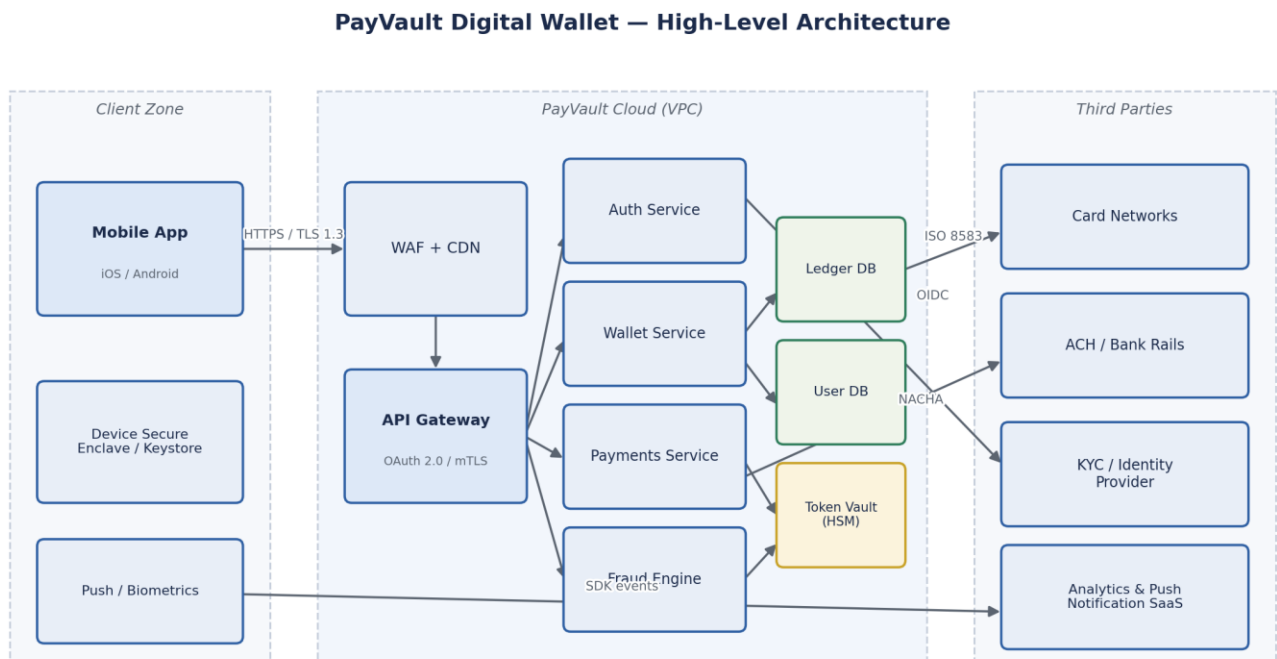


Figure 1. High-level architecture of the PayVault platform (fictitious).

3.2 Component Inventory

Component	Role	Key Data Handled	Exposure
Mobile App (iOS/Android)	Customer channel; biometric auth; device-bound keys in Secure Enclave/Keystore	Session tokens, display data, device keys	Untrusted endpoint
WAF + CDN	Edge filtering, bot management, TLS termination	Transit traffic	Internet-facing
API Gateway	AuthN/AuthZ enforcement, rate limiting, routing	OAuth tokens, request metadata	Internet-facing
Auth Service	Login, MFA, session issuance, account recovery	Credentials (hashed), MFA state	Internal
Wallet Service	Balances, P2P transfers, savings vault	Account balances, transfer intents	Internal
Payments Service	Card authorization orchestration to networks	Payment tokens, auth responses	Internal (CDE-adjacent)
Fraud Engine	Real-time risk scoring of logins and transactions	Behavioral and device signals	Internal
Ledger DB	Double-entry system of record	All monetary movements	Internal (crown jewel)
User DB	Profiles, KYC status, contact data	PII, KYC artifacts	Internal
Token Vault (HSM)	PAN tokenization/detokenization	Encrypted PANs	PCI CDE
Third parties	Card networks, ACH rails, KYC provider, analytics, and push SaaS	Varies by integration	External

4. Business Case for the Security Investment

The security program was evaluated as an investment decision rather than a compliance cost. All figures are fictitious and illustrative.

Line Item	Year-1 Cost	Basis
Fraud-stack uplift (liveness, device intel, consortium data)	\$1,150,000	Vendor licensing + 3 FTE-quarters integration
First-party telemetry pipeline (replaces analytics SDK)	\$620,000	Build + infra; removes \$180k/yr SDK license
Passkey rollout and SMS OTP retirement	\$430,000	Eng. effort + support/comms for migration

Line Item	Year-1 Cost	Basis
RASP, signed intents, HSM audits, IAM hardening	\$540,000	Tooling + security engineering capacity
Resilience (rate-limit tiers, push failover, ledger hash chain)	\$160,000	SRE + data platform capacity
Total program cost	\$2,900,000	—

Benefit Category	Year-1 Value	Basis
Fraud-loss avoidance	\$6.3M	55% modeled reduction of \$11.4M ALE
Regulatory-exposure reduction	\$1.4M	Expected-value reduction in fines/remediation (SDK egress, KYC gaps)
Support-cost reduction	\$500k	ATO and dispute ticket volume down ~35%
Enables remittance launch	\$6.0M revenue	Launch gated on Critical risks reaching Medium or below
Total quantified benefit	\$8.2M risk value + launch enablement	≈2.9x return on the \$2.9M program, excluding revenue enablement

Beyond quantified returns, the program materially strengthens the sponsor-bank relationship (by closing audit findings), reduces the PCI assessment scope, and positions the passkey experience as a customer-facing differentiator.

Prepared by the Meridian Pay Security Architecture team (fictitious) for training and illustrative purposes.